KEMSR-ARC-0001 / VERSION 1.0.0

Kano Election Monitoring & Situation Room Management Platform

Phase 0
Product & Engineering Blueprint

AWAITING REVIEW — NOT A PRODUCTION CERTIFICATION

Architecture • Authorization • Evidence custody • Offline operations
GIS • Recovery • Acceptance gates

Prepared 2 November 2026
Companion specifications and governance registers are maintained in the repository.

Section guide

Use the PDF bookmarks or select a section below. Companion specifications are listed in the reading guide.

Reading guide

1. Product requirements and operational mandate
2. Complete system module breakdown
3. Organizational and geographical hierarchy
4. Roles, permissions and administrative boundaries
5. Complete database ERD and relationship model
6. Supabase RLS and data-access strategy
7. Application architecture and design system
8. API architecture
9. Field-agent journeys
10. Senatorial commander journeys
11. Central situation room journeys
12. Incident response and escalation workflows
13. Result submission and verification
14. Media, evidence and chain of custody
15. GIS and geographical intelligence
16. Offline-first and low-bandwidth synchronization
17. Security threat model and data protection
18. Notifications, analytics and exports
19. Backup, disaster recovery and environments
20. Performance, capacity and reliability plan
21. Phased roadmap and acceptance gates
22. Risks, unresolved requirements and approval request

Download the 18-page review PDF · Editable Markdown source

Control	Value
Document ID	KEMSR-ARC-0001
Version	1.0.0 — review candidate
Date	2026-11-02
Repository	`baiitax/Ndc-room`
Branch	`arena/52212c3f-ndc-room`
Baseline	Initial README only; no application, database or deployment existed
Owner	Product owner and engineering lead — appointment outstanding
Classification	Internal engineering planning; contains no operational personnel data
Decision	**AWAITING PHASE 0 REVIEW — do not start Phase 1 automatically**

> This document specifies a system to be built. It does not certify a working or production-ready platform. No application components, production statistics, electoral records, Supabase migrations, live integrations or deployments have been created in Phase 0.

Reading guide

The blueprint below covers all 22 requested architectural areas. Detailed, controlled artifacts are linked rather than duplicated:

1. Product requirements
2. Module breakdown and dependency map
3. Organization and geographic data contract
4. Role and permission matrix
5. Complete conceptual ERD and table/relationship dictionary
6. Security, RLS and threat model
7. Application architecture and design system
8. API architecture
9. User journeys and operational workflows
10. Evidence and offline synchronization
11. GIS architecture
12. Backup, deployment and recovery
13. Roadmap and acceptance gates
14. Testing strategy
15. Decision register, research notes, and known issues
16. Implementation status and Phase 0 review report

Status vocabulary: **VERIFIED IN CODE / DATABASE / UI / END-TO-END** requires implementation evidence at that layer; **ARCHITECTURALLY DEFINED** means specified only; **PLANNED** means not yet

specified in sufficient detail; **BLOCKED** means an identified dependency prevents progress; **FAILED** means an executed check did not pass. A document check is not an application test.

1. Product requirements and operational mandate

1.1 Purpose

Provide one neutral, auditable observation and coordination system for a Kano-based election-monitoring organization. Central command, three senatorial situation rooms and authorized field observers work from the same records, with different permissions and interfaces. The platform supports Federal and State election configurations; it is not an INEC voting, collation or declaration system.

The operational problem is not simply collecting forms. It is maintaining trustworthy receipt, ownership, review and escalation of observations while personnel operate on shared devices, intermittent networks and constrained budgets. Safety, provenance and permission boundaries take precedence over visual spectacle or speed of declaration.

1.2 Goals and non-goals

Goals

- Onboard verified personnel and assign them to authorized electoral locations.
- Receive situation reports, result observations, incidents and emergency requests with durable receipts.
- Give commanders scoped coverage, workload, response and verification tools.
- Preserve original evidence and every material review or correction.
- Provide private communications, scoped GIS, operational exports and security oversight.
- Preserve locally saved work during connectivity failures and distinguish it from server-received work.
- Support a rehearsed election-day operation and a tested recovery procedure.

Non-goals

- Casting votes, accessing voter registers, operating BVAS, declaring winners or replacing INEC collation.
- Inferring individual voters' choices, profiling political loyalty, predicting winners or scoring agents by allegations or party preference.
- Covert or continuous location tracking; public exposure of agent positions or whistleblower identities.
- A guarantee of delivery over a disconnected network, legal admissibility of evidence, or independently certified end-to-end encryption.
- Autonomous enforcement actions, facial recognition, automated accusations or guilt assignment.

1.3 Users and command contexts

Persona	Primary responsibility	Default data boundary
Central super administrator	Govern identities, configuration, security and recovery	Explicit organization-wide administrative permissions; MFA and audit
Central commander	Statewide operational oversight and escalation	Authorized organization/election modules, all three districts
Central staff	Verification, intelligence, analysis, communications or evidence review	Explicit module grants; no automatic administrator rights

Persona	Primary responsibility	Default data boundary
Senatorial commander	Run one district's operation	Assigned district only; no implicit sibling-zone access
Zonal staff	Assist district operations	Assigned district and explicit module grants
Field agent	Observe, check in, report and request assistance	Own identity, assignments, submissions and conversations
Auditor / observer	Review approved history and accountability	Explicit approved-record and audit permissions; no mutations

The detailed PRD assigns requirement IDs, priorities and acceptance evidence. The role matrix is the normative permission specification.

1.4 Product invariants

1. An authenticated identity is not an authorized account. Activation, scoped roles and applicable MFA are separate checks.
2. A report's observation time, device time, server receipt time and review time are distinct.
3. Draft, queued, received, under review, verified, disputed and rejected are never collapsed into “submitted successfully.”
4. An authenticated result-sheet image does not make a transcription error-free. Document authentication and figure verification are separate reviews.
5. Only a separately authorized official-publication workflow can label a record “officially published,” with issuing authority, scope and source reference. A verified observer transcription remains an observation.
6. Originals and review history are append-only at the application layer. Corrections create versions; administrative database power is itself a controlled threat.
7. All counts are scoped, election-specific queries or maintained aggregates with a visible freshness time. Empty means zero only when the query succeeded; unavailable means unknown.
8. No interface, export, map, notification or search result may exceed the underlying database permission boundary.

2. Complete system module breakdown

Domain	Modules and responsibilities	First phase
Foundation	Design tokens, accessible components, layouts, error handling, environment validation	1
Identity	Authentication, profiles, scoped staff roles, invitations, MFA, sessions	2
Geography	Versioned imports, district/LGA/ward/PU hierarchy, validation, boundaries	2–3; GIS in 9
Organization	Situation rooms, staff verification, supervisor relationships, configuration	3
Coverage	Agent onboarding, assignments, reassignment history, check-in, availability	3

Domain	Modules and responsibilities	First phase
Field reporting	Categories, structured observations, drafts, corrections, review queue	4
Incidents	Triage, assignment, investigation, escalation, resolution and closure	5
Emergency	Priority alerts, acknowledgement, responders, response log, resolution	5
Evidence	Private uploads, quarantine, hashes, derivatives, access logs, annotations	6
Communications	Direct/group conversations, membership, messages, attachments, receipts	7
Results	Election configuration, parties/candidates, transcription, validation, independent review	8
GIS / analytics	Authorized layers, clusters, coverage, operational metrics, performance	9
Governance	Audit, security events, notifications, exports, retention, backup records	10; foundations earlier
Resilience	PWA shell, IndexedDB, transactional outbox, media recovery, sync controls	4 and 6 foundations; hardening in 11
Readiness	Cross-module E2E, authorization tests, load tests, restore drills, election simulation	12–13

Navigation is a projection of these modules, not the authorization model. Every requested central, zonal, field, public and shared-administration route is mapped in API_DOCUMENTATION.md. A Phase 1 visual shell must be labelled non-operational until its backing phase passes; it must not simulate live statistics.

3. Organizational and geographical hierarchy

```
Organization (one operating organization initially; organization_id retained)
└── Central situation room
    ├── Central operational teams
    ├── Kano North senatorial situation room
    ├── Kano Central senatorial situation room
    └── Kano South senatorial situation room
        └── Assigned LGA coordination → official ward → official polling unit
            └── Time-bounded agent assignments and supervisor relationships
```

“Kano Central Command” is the central organizational unit, **not** a fourth senatorial district. A district commander may supervise multiple LGA coordinators; multiple agents may observe a PU. An agent's current assignment does not rewrite the ownership or location of historical reports.

The requested coverage is three districts and all 44 LGAs. A 2022 report attributed to INEC Kano described 484 wards and 11,222 PUs; the 2023 governorship IReV snapshot also showed 11,222 expected results. These are historical reconciliation references, **not an approved current roster or dashboard totals** 3 4.

INEC's directory describes the State/LGA/Ward/PU code structure and links to its locator. The locator warns that its directions are approximate. Neither a scraped coordinate nor a boundary inferred from points is authoritative. See the official directory and locator.

Import contract: source agency, release/effective date, source URI, file hash, importer, schema version, official codes as text, parent validation, duplicate checks, coordinate provenance/accuracy and explicit

approval. Each election pins an approved geography version. Missing coordinates remain null; list views still work. Boundary polygons require an approved boundary source. No synthetic production geography or identifiers will be seeded. Details: geography contract.

4. Roles, permissions and administrative boundaries

Authorization combines:

`verified session ∧ active profile ∧ applicable MFA ∧ organization scope ∧ district scope ∧ module/action permission ∧ record policy`

- Roles are scoped grants, not a client-editable profile flag. Central scope does not silently include another organization.
- Staff use bounded functional roles or custom roles containing only allowed permission keys. Invitation or registration alone grants nothing.
- District roles require a district; central roles require organization scope. A user may hold multiple explicitly approved scopes, never an inferred “all zones” grant.
- Agents can create only within active assignments and their own identity. They cannot read other agents' contact details or change review state.
- Result verification requires `results.verify`; preparing a submission does not grant it. Default policy requires a reviewer other than the submitter. High-impact publication requires a second authorized approval.
- Auditors receive approved, minimally identifying records. Access to raw whistleblower identity or precise location is a separate grant, not an auditor entitlement.
- Privilege changes, account suspension, exports, evidence access, retention changes and restore requests are audited. Super administrators cannot erase application audit history.

RLS, grants, RPC checks and storage policies are specified in SECURITY.md. UI hiding is defense in depth only.

5. Complete database ERD and relationship model

The conceptual ERD covers every requested minimum table plus the additional import, versioning, outbox, idempotency and official-publication entities needed to enforce the workflows. The database dictionary defines purpose, principal fields, ownership, relationships, deletion rules and policy class for each table.

5.1 Core relationships

```
organizations → election_cycles → election_configurations → candidates
senatorial_districts → local_government_areas → wards → polling_units
profiles → user_roles → roles → role_permissions → permissions
profiles + election_configuration + polling_unit → agent_assignments
agent_assignments → checkins / situation_reports / result_submissions
situation_reports → immutable situation_report_versions → report_verifications
result_submissions → immutable result_submission_versions → result_entries
incidents → assignments / updates / escalations / resolutions
conversations → members / messages / receipts
evidence_files → typed links → reports, results, incidents, messages, alerts
all sensitive mutations → audit_logs and transactional outbox_events
```

5.2 Modeling decisions

- Internal UUID primary keys; official electoral codes are separate textual natural keys. Leading zeros survive.

- Geography is versioned. Composite foreign keys validate the district/LGA/ward/PU chain, not just independent IDs. Election-pinned geography prevents retrospective boundary changes.
- Operational records carry organization, district and election scope derived server-side from the PU or authorized conversation. Denormalized scope is protected and checked against parents for efficient RLS.
- `created_at`, `updated_at` where mutable, actor and version fields are standard. Immutable events have creation time and actor, not misleading update semantics. System jobs use a documented service actor rather than impersonating a person.
- Submission roots hold identity and controlled workflow state; version tables hold observations and figures. Review tables append decisions. A root's current-version pointer changes only through an authorized command.
- Messages, checkins, audit events and original evidence metadata are append-only. Message redaction is a restricted appended action, not silent history rewriting.
- `RESTRICT` protects operational history; membership/assignment end dates preserve history. Retention disposal is a governed workflow, not ordinary cascading deletion from a user's profile.
- PostGIS `geometry(...,4326)` with GiST indexes; optional coordinates and approved boundaries are distinct entities.
- Cursor pagination with stable `(created_at,id)` ordering; indexes on owner, district/election/time, workflow priority and every RLS lookup. Partial unique indexes prevent duplicate active assignments and idempotency replays.
- Transactional outbox rows commit with domain changes. Workers deliver notifications/exports/replication idempotently; an outbox is not a claim that a provider accepted a message.

No migration has been written or applied in Phase 0. Phase 2 must turn this conceptual model into reviewed, executable migrations and database authorization tests.

6. Supabase RLS and data-access strategy

Supabase documents that grants and RLS are separate controls and recommends RLS on every exposed table. The design enables and forces RLS, revokes default public/client grants, then grants only required operations. Helper functions live in a non-exposed authorization schema with fixed `search_path` and minimal execute privileges 1.

Policy families:

Data	Read	Write
Reference geography	Active users with relevant geography scope; no anonymous reads	Geography administrator import/approve RPC only
Profiles / roles	Self and authorized personnel managers; limited directory projection	Self-contact fields only; privilege writes through privileged RPC
Assignments / checkins	Own assignment or scoped coverage manager	Assignment manager / own checkin command; no client supervisor spoofing
Reports and results	Own submissions or scoped module readers; auditor approved projection	Own create/correction command; review only by authorized reviewer
Incidents / emergencies	Own limited status, assigned responder, scoped command	Own creation; scoped response transitions; confidential identity separately protected
Conversations	Active members only	Active members; server sender identity; membership administration restricted

Data	Read	Write
Evidence	Authorized linked-record reader with evidence permission	Reservation/finalization only; original bytes never updated by clients
Audit / security	Explicit audit/security roles; least-privilege projections	Append by trusted code; no client update/delete
Outbox / idempotency / imports	No direct client access except own receipt lookup where needed	Trusted transaction/worker only

`auth.uid()` supplies identity; editable user metadata never supplies permissions. Database helpers inspect active grants and account state. SECURITY DEFINER code is exceptional, narrowly owned, validates caller and scope, and is never a generic SQL or service-role proxy. Views use invoker semantics or explicit safe projections; materialized aggregates are not exposed directly.

Storage buckets are private. Supabase Storage supports RLS and signed downloads; a signed URL is a temporary bearer capability, not a per-request identity check 1. Use approximately 60-second expiry for sensitive evidence, no caching where controllable, and an authenticated streaming proxy where immediate access control matters. Supabase notes individual signed URLs cannot simply be revoked; key rotation and CDN behavior must be part of incident response 2.

Realtime uses private channels and policies on `realtime.messages`. Authorization is cached for a connection, so suspension or membership removal also revokes sessions and forces channel rejoin through a membership epoch. Broadcast minimal IDs, not incident descriptions or evidence URLs. Postgres Changes remain RLS-filtered; never use sensitive DELETE payloads as an information channel 1.

7. Application architecture and design system

7.1 Selected architecture

A **modular Next.js application plus Supabase managed services**, with a small set of isolated asynchronous workers. Avoid microservices before measured scale requires them.

```
Field PWA / zonal tablet / central desktop
        | HTTPS; same-origin application API
Next.js App Router on Vercel
  ├── Server Components: scoped reads and initial payloads
  ├── Route handlers / Server Actions: validated commands, CSRF/origin checks
  ├── Authorization-aware navigation (not a security boundary)
  └── User-context Supabase client; RLS remains enforced
        |
Supabase Auth — PostgreSQL + PostGIS + RLS — Private Storage
        |               |                        |
        |               ├── Realtime authorization/private topics
        |               └── Transactional outbox → isolated workers
        |                     ├── notification/email/SMS adapters
        |                     ├── evidence scanning/derivatives/replication
        |                     └── exports and aggregate refresh
        └── short-lived session/JWT; no privileged key in browser

Browser service worker: public app shell only
IndexedDB: per-account drafts, reference snapshots, outbox and media
```

Ordinary database operations use the authenticated user's context. A server component is not automatically trusted. Service-role/worker credentials exist only in isolated server secret stores and never in `NEXT_PUBLIC_*`, client bundles, service workers or cached API responses. Most worker tasks should use a constrained database worker identity; service-role use requires a documented exception.

7.2 Stack and compatibility gate

Requested stack retained: Next.js App Router, strict TypeScript, Tailwind CSS, shadcn/ui, Lucide, React Hook Form, Zod, TanStack Query where needed, Recharts, MapLibre GL JS, Supabase and Vitest/Playwright.

Registry `latest` values observed on 2026-11-02 include Next **16.4.3**, React **19.3.1**, TypeScript **7.0.2**, Tailwind **4.3.3**, Supabase JS **2.118.0**, MapLibre **6.16.0**, Zod **4.6.7** and Vitest **5.0.5**. These are observations, not compatibility certification. Phase 1 must lock a tested compatible set, including shadcn/TypeScript tooling, rather than repeatedly installing floating `latest`. The sandbox has Node **22.22.3**; Next's observed requirement is ≥20.9 and Supabase JS's is ≥22. See research notes.

7.3 UX direction

Premium but restrained glass panels over navy/charcoal surfaces; light theme with equivalent contrast. Solid fallbacks for low-power/reduced-transparency devices. Blur is decorative and limited; critical alerts, tables and forms retain opaque/high-contrast backgrounds. Tokens cover color, typography, spacing, radii, elevation, focus and motion. Status always has text/icon, not color alone.

- Central: collapsible sidebar, dense-but-readable tables, persistent alert rail, command search, zone comparison.
- Zonal: larger touch targets, district context always visible, workload-first layout.
- Field: assignment first; check-in, report, incident and emergency actions; bottom navigation; minimal typing and progressive disclosure.
- Accessibility target WCAG 2.2 AA, keyboard operation, visible focus, screen-reader labels, reduced motion and 44px minimum touch targets (larger primary field actions).
- Hausa/English language readiness; translation and field comprehension validation require operational approval. No automatic language rollout claim.
- Skeletons only while loading; distinguish “no reports,” “not authorized,” “offline” and “query failed.”

The design specification includes interaction and performance rules. No components are generated in this phase.

8. API architecture

Use same-origin `/api/v1/*` route handlers for commands and sensitive reads; use typed Supabase queries for simple scoped reads where appropriate. PostgreSQL RPCs encapsulate multi-table invariants. Do not expose a generic table-write API to the browser.

Command envelope: schema version, client request UUID, idempotency key where repeatable, expected entity version, typed payload and explicitly consented optional location. Server derives actor, organization, district, reference number, receipt time and initial review state. Responses return resource ID, reference, version, authoritative receipt time and state.

Key command groups: invitations/roles; imports/assignments/checkins; report submission/correction/review; incident transitions; emergency acknowledgement; upload reservation/finalization/signed access; conversation membership/messages; result versions/review; exports; retention and restore requests. Exact routes, permissions and error semantics are in API_DOCUMENTATION.md.

Controls: Zod validation at ingress plus database constraints; body limits; cursor pagination; rate limits by account/IP/action; origin checks and appropriate CSRF protection for cookie-authenticated mutations; no permissive CORS; structured errors with correlation IDs but no SQL, tokens or private evidence paths. Duplicate idempotency key with the same payload returns the original receipt; a different payload returns conflict. Offline retries never generate a new observation merely because a response was lost.

9. Field-agent journeys

1. **Invitation → verified identity:** accept expiring invitation, verify contact, set password, accept privacy notice, complete training/profile verification; await explicit activation and assignment. MFA offered, required where policy demands.
2. **Assignment → check-in:** view official PU description; transparent optional location permission; arrival/available/check-out events with accuracy and receipt. GPS denial does not silently fail a report or enable background tracking.
3. **Ordinary observation:** select assigned PU and category → structured answer → optional description/media → review → save/send. Target 30–60 seconds for a practiced ordinary report, to be measured. Media does not block text receipt.
4. **Connectivity loss:** local transaction saves draft and outbox together; UI says “Saved on this device — not received.” Retry or manual sync; server receipt changes state only after acknowledgement.
5. **Result observation:** select configured election/PU → transcribe figures → see arithmetic warnings → attach sheet when safe → submit version → track review. Never labelled official by the agent.
6. **Incident:** choose category/severity, minimum necessary facts, safety/assistance flags and optional evidence; submit without confronting anyone. Confidentiality option depends on approved policy.
7. **Emergency:** select type, optional location and brief note, confirm quickly; show “sending,” “received,” “acknowledged,” or “not sent.” Always show approved direct emergency guidance; the app is not a substitute for emergency services.
8. **History/profile:** view own submissions, corrections and verification; update contact details; inspect queued work and safely sign out of a shared device.

Detailed preconditions, failures and acceptance checks: user journeys.

10. Senatorial commander journeys

- Open a district-pinned dashboard; see assigned commander/staff, checkins, coverage gaps, workload and response times with freshness labels.
- Verify and activate agents within delegated limits; assign/reassign coverage with reason and effective time; review historical assignments.
- Triage incoming reports; request correction without altering originals; assign incident owners; escalate high/critical cases to central command.
- Verify results only with explicit permission and evidence-review workflow; disputed figures remain disputed rather than being overwritten.
- Message agents, supervisors and central command in authorized conversations; removed members lose future access.
- Review district map/list and export only authorized scope. Attempts to alter a district ID or resource UUID must fail at the database/API, not just redirect in the UI.

11. Central situation room journeys

- Statewide operational overview with district comparisons, missing coverage, pending reviews and critical workload; no invented totals.
- Drill into a district/LGA/ward/PU and inspect provenance, version history and evidence references.
- Govern personnel, roles, election configuration, geography releases and escalation policy with privileged-action audit.

- Coordinate cross-district incidents while respecting confidential-source restrictions; distinguish operational visibility from raw identity access.
- Review verified summaries separately from incoming observations and official publications.
- Request scoped exports; download through expiring authorized links after policy checks; record export purpose and contents.
- Review security events, session anomalies, backup verification and recovery readiness; request a restore with dual approval, never a one-click destructive production overwrite.

12. Incident response and escalation workflows

Primary lifecycle:

`SUBMITTED → RECEIVED → TRIAGED → ASSIGNED → UNDER_INVESTIGATION → ACTION_REQUIRED → RESOLVED → CLOSED`

Additional dispositions: escalated, disputed, duplicate and insufficient evidence. Escalation is an event/ownership change, not deletion of the original state. Duplicate links to a canonical incident; insufficient evidence can be reopened with new material. Every transition records actor, time, prior/new state, reason and expected version. Closure requires authorized role and resolution notes.

Severity is an operational triage label, not a finding of guilt. Proposed defaults: critical immediate command notification; high district priority and escalation when unacknowledged; medium queued for triage; low/informational reviewed in normal workflow. Time thresholds are configuration, not yet agreed policy. Safety flags can elevate handling without asserting an allegation is true.

Emergency workflow is separate: alert → durable receipt → district notification → acknowledgement → assigned response → resolution; central escalation according to severity/time. Critical in-app priority does not bypass carrier, browser or operating-system limitations. Offline alerts are explicitly unsent. See workflow state tables.

13. Result submission and verification

- Election configuration pins jurisdiction, election type, date, approved geography, candidate/party roster and form schema. No current candidates or parties are assumed.
- Fields include optional officially available registered voters, accredited voters, valid votes, rejected votes, total cast, candidate entries, observations, sheet evidence and timestamps.
- Negative or non-integer counts are rejected. Valid + rejected versus cast, candidate sum versus valid, and cast/accredited versus registered are checked. Discrepancies are flagged for review; values are never silently “fixed.”
- Multiple agents may independently submit observations for the same PU. Exact replays are deduplicated by actor/operation/idempotency key; distinct submissions are preserved and linked for comparison, not erased as duplicates.
- Corrections create a new immutable version with reason and prior-version reference. Review decisions reference a specific version.
- Verification checks document provenance, legibility, transcription, arithmetic and scope. Default dual control: submitter cannot verify own result. Rejection/dispute requires a reason and preserves the original.
- Official publication is a separate record with issuing authority, declaration/publication time, source document/reference, authorized importer and approver. IReV images and observer-verified figures do not themselves constitute a final declaration.

State model: `DRAFT → RECEIVED → UNDER_REVIEW → VERIFIED | DISPUTED | REJECTED`, with `CORRECTION_REQUESTED` and a new version. `OFFICIALLY_PUBLISHED` belongs to the official-publication entity, not an upgraded transcription label.

14. Media, evidence and chain of custody

Private buckets: quarantine originals, approved originals, derivatives and restricted exports. Upload flow: authorize and reserve → upload original to quarantine → verify size/signature/hash and scan → finalize immutable evidence record → create labeled derivatives → attach through typed links. Text submissions never wait for large media.

Photographs retain an original; resizing creates a separate derivative. Audio bitrate and video resolution are chosen before recording. A compressed capture is the original of that capture; later transcoding does not replace it. Where bandwidth prevents original upload, the UI says the original remains local and must not imply central custody.

Evidence metadata includes UUID/reference, uploader, source filename, MIME/signature, bytes, SHA-256, capture/receipt times, linked scope, verification state and access history. Hashes establish byte integrity relative to the recorded hash, not truth or legal admissibility. Server hashes are authoritative; client hashes are compared. Original objects have no client overwrite/delete path. Annotations are versioned separately.

Malware scanning is an integration decision; until an approved scanner is deployed, uploads stay quarantined and production evidence acceptance is blocked. Signed access is short-lived and logged; highly sensitive exports use an authenticated proxy. No public bucket, executable SVG/HTML preview or claim of E2EE. Full protocol: offline and evidence architecture.

15. GIS and geographical intelligence

MapLibre is dynamically loaded only on map routes. PostGIS stores validated official boundaries and optional sourced PU coordinates. An election pins a geography release; boundaries are not guessed from markers. Base-map tiles and fonts must be self-hosted or use an approved provider with budget, licensing and privacy review. A boundary-only/offline list mode avoids external tile dependency.

Layers: state/district/LGA/ward boundaries, authorized PU status, assigned coverage, explicit checkins, incidents and result-submission status. Filters include election, geography, time, severity and review status. Clustering or server-side grid aggregation limits payload size; detailed records load on selection. Heatmaps show observation coverage, not voter support.

Precise agent positions are not a default command layer. Only explicit, consented checkins may be shown to authorized personnel, with retention limits and an accessible list alternative. Field agents do not receive other agents' locations. All map APIs apply the same RLS scope as tables; static tiles must never contain sensitive operational data. See GIS architecture.

16. Offline-first and low-bandwidth synchronization

The PWA caches only the public shell and static assets. Account-specific reference snapshots, drafts and media live in per-account IndexedDB stores, not shared HTTP caches. A service worker does not receive refresh tokens or privileged credentials.

Local states: `draft → queued → sending → received`, with `retry_wait`, `failed`, `conflict` and `rejected` branches. IndexedDB transactions save payload, attachment references and outbox entry atomically. Retry uses the same idempotency key and exponential backoff with jitter; automatic attempts are bounded but work is never silently discarded. Background Sync is optional; visible manual sync and foreground resume are the portable baseline.

Server receipt is authoritative. Client observation/capture time is preserved separately and may be flagged for clock skew. Late submission acceptance depends on approved assignment and election policy. Reassignment never rewrites old records. Conflicting expected versions require explicit user resolution; a new key is not an automatic conflict fix.

Logout on a shared device offers an explicit warning and choice to erase local data; unsent work is never silently deleted. Session expiry requires reauthentication before sync. Browser storage can be evicted or unavailable, so the UI reports persistence/quota failures and requests backup/export where safe. No promise of unlimited offline storage or offline login. Detailed receipt, upload-recovery and encryption limitations: offline architecture.

17. Security threat model and data protection

Primary assets: identities/contact details, assignments, unpublished observations/results, allegations, confidential sources, original evidence, private messages, audit records and privileged credentials. Trust boundaries include browser/device, Vercel, Supabase services, provider adapters, backup storage and human administrators.

Top threats and controls:

Threat	Required mitigation	Verification
Cross-zone/agent data access	Scoped RLS, grants, safe projections, private storage/Realtime	Negative tests across every role/resource and direct API
Privilege escalation	Server-only role commands, MFA, least privilege, audit	Forged metadata/role/owner/verification tests
Account/device compromise	Contact verification, session revocation, field device hygiene, rate limits	Suspended-user and stolen-session scenarios
Evidence tampering/exfiltration	Immutable originals, hashes, signed/proxied access, access logs	Hash mismatch, overwrite, expired-link and unauthorized-download tests
Malicious upload/XSS	Signature/size checks, quarantine scan, safe previews, CSP	Polyglot/script/upload abuse corpus
False or disputed information	Provenance, independent review, versioning, neutral labels	Correction and unauthorized approval workflows
Provider/outage/data loss	Durable outbox, independent DB/media backups, recovery drills	Interrupted writes and measured restoration
Insider/admin misuse	Dual control, append-only audit, external tamper-evident copy	Audit-delete and privileged-export tests
Notification leakage	Generic lock-screen text, no media/evidence detail in pushes	Payload inspection and device tests

Security design includes HTTP headers, input validation, dependency/secret scanning, login controls, session visibility, security-event triage and penetration testing. Supabase MFA supplies `aal2`; frontend checks alone do not enforce it Supabase MFA.

NDPA 2023 work requires an identified controller, documented lawful bases by purpose, privacy notices, minimization, processor/transfer review, DPO/applicability assessment, data-subject request process, DPIA and breach procedure. Do not treat consent as the only lawful basis or assume journalism/exemption applies. The Act's text includes a 72-hour Commission notification requirement for likely-risk breaches; counsel must validate the complete operational procedure 1. This blueprint is not a legal compliance certificate. Full threat model and RLS plan.

18. Notifications, analytics and exports

Notifications: transactional outbox → in-app/Realtime first; optional Web Push, email and SMS adapters. Store preferences, priority, attempts, provider receipt and failures separately. Critical messages receive higher queue priority, not a guarantee against network failure. Lock-screen content is generic. Provider selection and consent remain open decisions.

Performance analytics: assignment completion, checkin timeliness, required-report completeness, correction rate and upload reliability. Incident counts are contextual, never a loyalty or productivity score. “Active” means a defined recent checkin/availability/heartbeat window, not continuous surveillance. Every metric has a numerator, denominator, scope, freshness and missing-data policy.

Exports: PDF, XLSX and CSV generated asynchronously from authorized, version-pinned queries. Include reference, generation time, generator, election/geographic/date scope, verification caveats and row provenance. CSV/XLSX formulas are neutralized; sensitive exports require purpose, expiry and audit. Evidence packages contain a manifest and hashes; a ZIP is not automatically a legally certified bundle. Large or confidential exports use restricted streaming/download controls.

19. Backup, disaster recovery and environments

Separate development, staging and production Supabase projects and Vercel environments. Synthetic fixtures only in automated tests; no production personal data in development. Staging access and provider credentials are isolated. Domain, hosting region, budget and providers require approval.

Supabase database backups do **not** include Storage object bytes. PITR is a paid option with compute prerequisites and replaces daily backups when enabled; it is not an evidence backup Supabase backups.

Proposed targets, subject to budget and measured drills:

Asset/service	Proposed RPO	Proposed RTO
Acknowledged operational database records	≤5 minutes with PITR	≤2 hours for intake/review in recovered environment
Acknowledged original evidence	≤15 minutes via tested replication	≤4 hours for evidence access, volume-dependent
Configuration/code/secrets recovery material	Versioned before every release	Within intake recovery objective
Full analytics/GIS/export services	Same database recovery point	≤8 hours

Daily-only database backups cannot meet a five-minute RPO. If PITR/replication is not funded, record the actual higher RPO and obtain risk acceptance. Evidence replication must copy object bytes and a verifiable manifest, not just `storage.objects` metadata.

Backups use separate credentials and restricted, versioned/immutable storage where supported. Recovery is dual-approved, rehearsed in isolation, reconciles DB references to object hashes, validates auth/roles/policies and replays outstanding outbox safely. A requested backup is not “verified” until restoration and integrity checks succeed. Responsibilities, retention/legal hold and the detailed runbook are in DEPLOYMENT.md. No restore has been performed in Phase 0.

20. Performance, capacity and reliability plan

Targets are **unmeasured** until Phase 11–12 tests:

- Field first meaningful content proxy: LCP ≤3 seconds at p75 on the agreed constrained mobile profile; shell remains usable offline.
- Ordinary text command receipt: p95 <5 seconds on the agreed stable network, excluding media.
- Normal dashboard/list query interaction: p95 <2 seconds, with defined percentile/window and dataset.
- Healthy-network critical event to authorized connected UI: p95 <5 seconds, measured from commit to render; separate acknowledgement time.
- No loss of acknowledged submissions in fault-injection tests; no silent loss of locally committed drafts within documented browser-storage limits.

Planning envelope, not asserted production load: 5,000 registered agents, 2,000 concurrently connected, 20 sustained writes/s, 100 writes/s burst and a 10,000-agent stress scenario. Historical PU count is only a geographic sizing reference. Model opening/checkin, midday reports and closing/results bursts separately. Include media bytes, Realtime fan-out, export jobs and reconnect storms.

Use connection pooling, scoped indexes, server aggregates, pagination, bounded realtime subscriptions, compressed images, low-resolution video defaults and lazy GIS/chart imports. Cache static/reference data with versions; never cache privileged HTML or signed evidence URLs in the service worker. Define provider quotas and cost alerts before load testing. Do not upsize infrastructure blindly: capture query plans and bottlenecks first.

21. Phased roadmap and acceptance gates

Each phase produces code/migrations appropriate to its scope, tests, documentation, a completion report and explicit acceptance. Phase 0 review is the first gate. Security-critical invariants are introduced with their tables, not postponed until Phase 10.

Phase	Outcome	Principal exit gate
0	Reviewed blueprint and decisions	Product/operations/security approval; no implementation claim
1	Foundation and three non-operational layouts	Strict checks, responsive/accessibility tests, no broken shell routes
2	Auth, schema, geography foundation and RLS	Real login, role routing, cross-zone denial, no exposed secrets
3	Personnel and coverage	Verified onboarding, scoped assignments, auditable changes/checkins
4	Field reporting	Durable receipts, review history, persistent drafts, idempotency
5	Incidents/emergency	Prioritized alerts, authorized response, complete transition history
6	Evidence	Private upload/retry, original integrity, quarantine and access logs
7	Communication	Membership-authorized realtime, history, receipts and attachments
8	Results	Validated versioned observations, independent review, official separation
9	GIS/analytics	Approved geography, scoped layers, real aggregates, list fallback

Phase	Outcome	Principal exit gate
10	Governance/recovery	Audit/security workflows, export controls, successful restore drill
11	Offline/performance	Reconnect/refresh/interrupted-upload tests and measured budgets
12	Integrated assurance	E2E/RLS/security/load/mobile/restore evidence; no open critical/high risk
13	Controlled production readiness	Formal operational acceptance and full synthetic election simulation

The roadmap expands objectives, implementation, migrations, frontend/backend/security work, tests, artifacts and pass/fail criteria for **every phase**. Phase dependencies may overlap only with explicit interface contracts; a later UI is not evidence of an earlier backend capability.

22. Risks, unresolved requirements and approval request

22.1 Principal risks

Risk	Mitigation / decision
Current official geography or boundaries unavailable	Obtain approved release; import quarantine; no invented coordinates; list fallback
Shared/compromised field devices	Minimize cached PII, reauthentication, purge controls, training; residual browser risk documented
Connectivity and reconnect bursts	Durable outbox, text-first receipt, backoff, load tests, operational fallback
Sensitive evidence or source exposure	Default confidential handling, separate identity permission, short-lived access, audit
False verification or political misuse	Neutral metrics, provenance, independent review, official-publication separation
Supabase/egress/media cost uncertainty	Measure representative media workload; budget/caps before election commitment
Realtime revocation delay	Session/channel revocation plus epoch; test actual removal latency
Backup appears healthy but media missing	Independent object replication and full reference/hash reconciliation
Vendor/legal/region constraints	Controller/processor and cross-border review before real data
Large scope mistaken for readiness	Phase gates, status register, no production claim without evidence

22.2 Decisions required

The decision register records owners and blocking phases. Key questions:

1. Who is the operating organization/data controller, product owner, security owner and DPO/contact?
2. Which election cycle/date, official geography release and boundary source are approved? Is a current machine-readable roster available?

3. What are the expected agent/staff counts, devices, languages, media volume, budget and deployment regions?
4. Which identity/contact method, field MFA policy, anonymous/confidential reporting policy and retention/legal-hold rules apply?
5. Who may verify results and publish official-source records? What are the incident/escalation thresholds and emergency contacts?
6. Which email/SMS/push, malware scanning, monitoring and independent backup providers are approved?
7. Who signs operational, security and production acceptance, and what is the election-day fallback procedure?

These do not prevent documenting the architecture. Unresolved production-critical items block their indicated phase or live-data use; they must not be silently converted into defaults.

22.3 Review checklist and sign-off

- [ ] Product scope, non-goals and neutral observation language approved.
- [ ] Three-zone hierarchy, role matrix and delegated administration approved.
- [ ] Data model, versioning, official-result separation and RLS strategy approved.
- [ ] Offline receipt semantics and evidence custody limitations understood.
- [ ] Geography acquisition and legal/privacy responsibilities assigned.
- [ ] Performance/recovery targets and budget owners accepted or revised.
- [ ] Phase 1 scope and compatibility gate approved.

Approval role	Name / decision / date
Product owner	Pending
Election operations lead	Pending
Security/privacy lead	Pending
Engineering lead	Pending

Recommended next action: review this blueprint and the decision register. After explicit approval, begin **Phase 1 only**: project foundation, design system and clearly labelled non-operational layouts. Do not interpret delivery of this document as permission to deploy or process real election data.